

Lab7:IoT & Enterprise Network Forensic Investigation Using Wireshark

Lab Overview

In this lab, a network forensic investigation involving BookWorld was conducted, a major online bookstore. Recently, unusual behavior has been detected in BookWorld's database activity, including spikes in query volumes and server resource usage, suggesting the possibility of a cyberattack.

AS part of a Digital Forensics team. The business is concerned about the integrity of customer data and its internal systems. My mission is to:

- * Conduct a thorough forensic analysis of the network traffic
- * Identify how the attacker gained access
- * Assess the scope of the breach
- * Prepare findings in a comprehensive report

Important:

This lab is intentionally designed without step-by-step filtering hints. You are expected to apply the packet analysis, filtering, and pivoting techniques in Lab 6 to successfully complete this Lab.

Exercise 1:

The overall traffic behavior.

WebInvestigation.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Wireshark - Protocol Hierarchy Statistics - WebInvestigation.pcap

Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes	End Bits/s	PDI
Frame	100.0	88862	100.0	28629039	80 k	0	0	0	888
Ethernet	100.0	88862	4.3	1244068	3,514	0	0	0	888
Internet Protocol Version 4	100.0	88862	6.2	1777240	5,020	0	0	0	888
User Datagram Protocol	0.1	122	0.0	976	2	0	0	0	122
Data	0.1	122	0.0	5368	15	122	5368	15	122
Transmission Control Protocol	99.9	88740	9.9	2847104	8,042	5313	178148	503	887
Hypertext Transfer Protocol	93.9	83418	38.8	11096504	31 k	41759	4368214	12 k	834
Portable Network Graphics	0.0	3	0.0	4071	11	3	4071	11	3
MIME Multipart Media Encapsulation	0.0	1	0.0	441	1	1	441	1	1
Line-based text data	46.9	41645	40.7	11664808	32 k	41645	11664808	32 k	416
HTML Form URL Encoded	0.0	4	0.0	129	0	4	129	0	4
Compuserve GIF	0.0	6	0.0	1218	3	6	1218	3	6
Data	0.0	9	0.0	9	0	9	9	0	9

The captured traffic is heavily web-based, with HTTP accounting for the majority of observed packets. Most communication occurs over TCP, indicating sustained client-server interactions.

Do you observe repeated connections or unusual communication patterns?

Yes. The extremely high volume of HTTP traffic over 83,418 packets suggests repeated interactions with the web application.

What early indicators suggest malicious activity?

1. Excessive HTTP traffic volume.
2. Large number of repeated web requests.
3. Significant amount of line-based text data transferred through HTTP.
4. Traffic concentration around web services.

Step 2: Identifying Suspicious Hosts

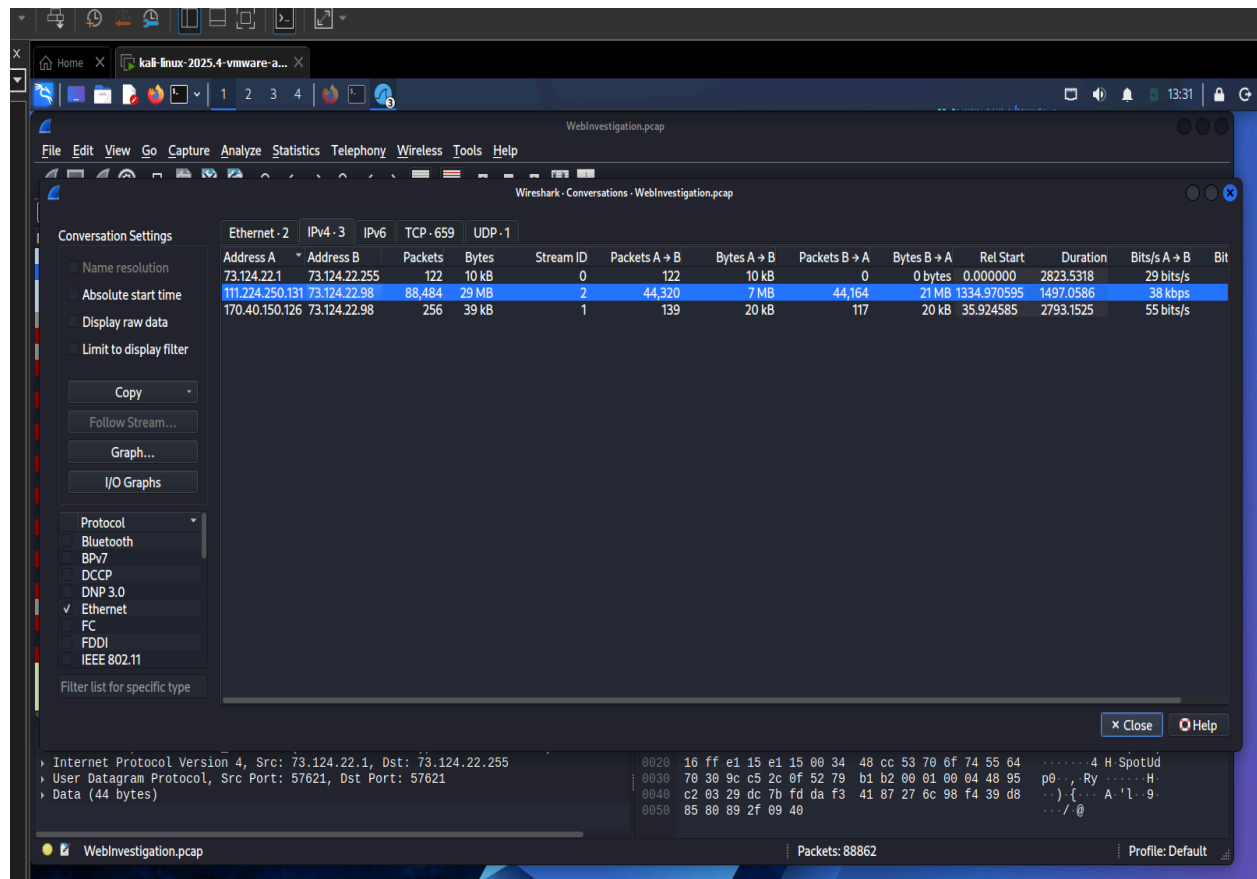
1. Using Wireshark statistics and conversation analysis features.

Identify:

- * External systems communicating excessively with BookWorld servers
- * Internal servers receiving abnormal traffic volumes

Exercise 2:

- * Identifying one suspicious external IP address.



Suspicious External IP Address here is:

111.224.250.131

Why this IP is considered suspicious based on traffic behavior?

1. Generated 88,484 packets, far more than any other host.
2. Transferred approximately 29 MB of data.
3. Maintained a long communication session about 1497 seconds.
4. Responsible for nearly all significant activity observed in the capture.

Exercise 3:

The screenshot displays a Kali Linux virtual machine environment. The main window is Wireshark, showing a capture of an HTTP stream (tcp.stream eq 42) from a web browser. The packet list on the left shows packet 428 selected, which is an HTTP GET request. The packet details pane on the right shows the structure of the request and response. The packet bytes pane at the bottom shows the raw data of the selected packet.

Packet List:

No.	Time	Source
422	1692.515961	111.224
424	1692.516168	73.124
425	1692.517011	111.224
426	1692.547971	111.224
427	1692.548279	73.124
428	1692.549222	73.124
429	1692.550021	73.124
430	1692.550681	111.224
431	1692.554547	111.224
432	1692.554716	73.124

Packet Details (428):

HTTP/1.1 200 OK

Date: Fri, 15 Mar 2024 12:07:33 GMT

Server: Apache/2.4.52 (Ubuntu)

Vary: Accept-Encoding

Content-Encoding: gzip

Content-Length: 144

Connection: close

Content-Type: text/html; charset=UTF-8

No results found<form action="/search.php" method="get">
<input type="text" name="search" placeholder="Search for books...">
<input type="submit" value="Search">
</form>

Packet Bytes:

Frame 428: Packet, 425 bytes

Ethernet II, Src: VMware_b6c

Internet Protocol Version 4,

Transmission Control Protocol

Hypertext Transfer Protocol

Line-based text data: text/html

A malicious HTTP GET request was sent to:

/search.php

using the parameter:

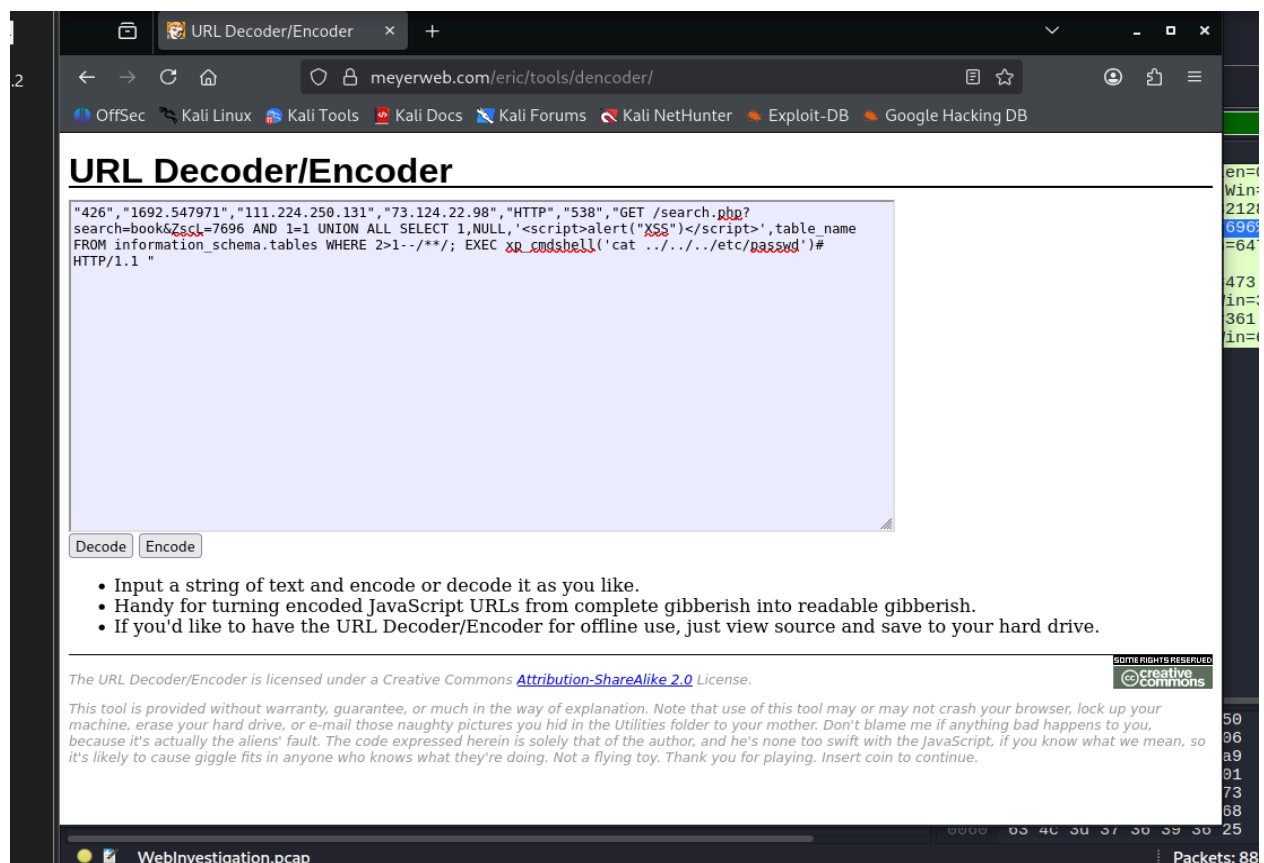
search=

* Which endpoints or parameters appear abnormal?

Entry Point

1. /search.php
2. Parameter: search=

* Do you observe patterns consistent with brute-force, enumeration, or data extraction?



Yes:

1. The attacker tried to inject SQL injection which payload contains: UNION ALL SELECT used to extract data from a database.

2. The request references : information_schema.tables

indicated an attempt to enumerate database tables and discover the database structure.

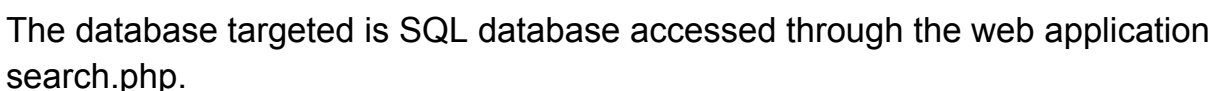
3. The payload also includes: EXEC xp_cmdshell(...)

suggesting an attempt to execute operating system commands and access sensitive files.

There is no direct evidence of a password brute-force attack in the provided request, but there is clear evidence of automated probing and exploitation of the web application.

Exercise 4:

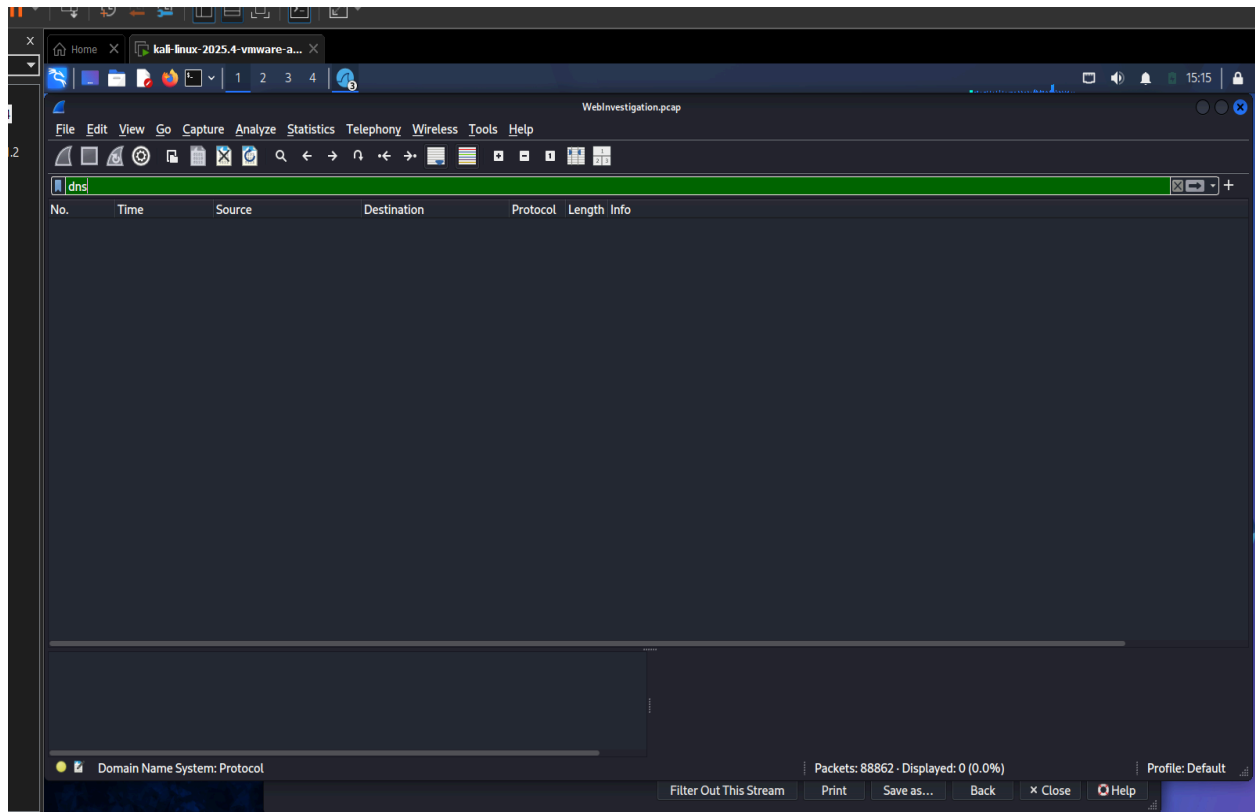
* Identify which database services appear to be targeted.



The use of UNION ALL SELECT, information_schema.tables, and sqlmap indicates database enumeration and unauthorized attempts to extract database information.

Exercise 5:

- * Identify unusual or suspicious domain queries.
- * Do any domains appear unrelated to BookWorld operations or algorithmically generated?



Dns filter shows 0 packets, indicating that no DNS queries were observed in the captured traffic

2. Data Exfiltration Indicators

Analyze outbound traffic patterns.

Exercise 6:

- * Is there evidence of large or abnormal data transfers?

Yes. The conversation between 111.224.250.131 and 73.124.22.98 transferred about 29 MB of data, which is significantly higher than other communications.

- * Which protocol or method appears to be used for exfiltration?

The data appears to have been transferred over HTTP, likely through SQL injection-based data extraction using the vulnerable web application.

Step 5: Attack Timeline Reconstruction

1. Identified:

- * Initial access
- * Exploitation phase
- * Data exfiltration phase

2. Use packet timestamps to reconstruct the incident timeline.

Exercise 7:

- * Reconstruct the attack sequence step by step.

From my findings so far:

1. The attacker connected to the BookWorld web server from 111.224.250.131.
2. SQLMap was used to send SQL injection payloads to search.php.
3. Database enumeration was performed using information_schema.tables.
4. Data was extracted through repeated HTTP requests.

- * At what point was customer data most at risk?

Customer data was most at risk during the database enumeration and data extraction phase after the SQL injection attack succeeded.

FORENSIC INVESTIGATION REPORT - BOOKWORLD NETWORK BREACH

Executive Summary

An investigation revealed that an external attacker exploited a web application vulnerability to perform SQL injection attacks against BookWorld's database. Evidence indicates database enumeration and possible data extraction through HTTP traffic.

Attack Timeline

1. Attacker connected from IP 111.224.250.131.
2. SQLMap was used against the search.php endpoint.
3. Database enumeration was performed using information_schema.tables.
4. Repeated HTTP requests were used to extract data.

Entry Point and Exploited Services

1. Entry Point: /search.php
2. Exploited Service: HTTP Web Application (Port 80)
3. Attack Method: SQL Injection

Affected Systems and Data

1. BookWorld web server
2. Backend database
3. Potential exposure of customer records

Indicators of Compromise (IPs, domains, ports)

1. Suspicious IP: 111.224.250.131
2. Target Host: bookworldstore.com
3. Port: 80 (HTTP)
4. Tool: sqlmap 1.8.3

Supporting Evidences

Wireshark · Follow HTTP Stream (tcp.stream eq 42) · WebInvestigation.pcap

File Edit View Go Capture Analyze

tcp.stream eq 42

No.	Time	Source
422	1692.515961	111.224
424	1692.516168	73.124
425	1692.517011	111.224
426	1692.547971	111.224
427	1692.548279	73.124
428	1692.549922	73.124
429	1692.550021	73.124
430	1692.550681	111.224
431	1692.554547	111.224
432	1692.554716	73.124

GET /search.php?search=book&ZsCL=7696%20AND%201%3D1%20UNION%20ALL%20SELECT%201%2CNULL%2C%27%3Cscript%3Ealert%28%2XSS%22%29%3C%2Fscript%3E%27%2Ctable_name%20FROM%20information_schema.tables%20WHERE%202%3E1--%2F%2A%2F%3B%20EXEC%20xp_cmdshell%28%27cat%20.%.%2F.%.%2F.%2Fetc%2Fpasswd%27%29%23 HTTP/1.1

Cache-Control: no-cache
User-Agent: sqlmap/1.8.3#stable (https://sqlmap.org)
Host: bookworldstore.com
Accept: */*
Accept-Encoding: gzip, deflate
Connection: close

HTTP/1.1 200 OK
Date: Fri, 15 Mar 2024 12:07:33 GMT
Server: Apache/2.4.52 (Ubuntu)
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 144
Connection: close
Content-Type: text/html; charset=UTF-8

No results found<form action="/search.php" method="get">
<input type="text" name="search" placeholder="Search for books...">
<input type="submit" value="Search">
</form>

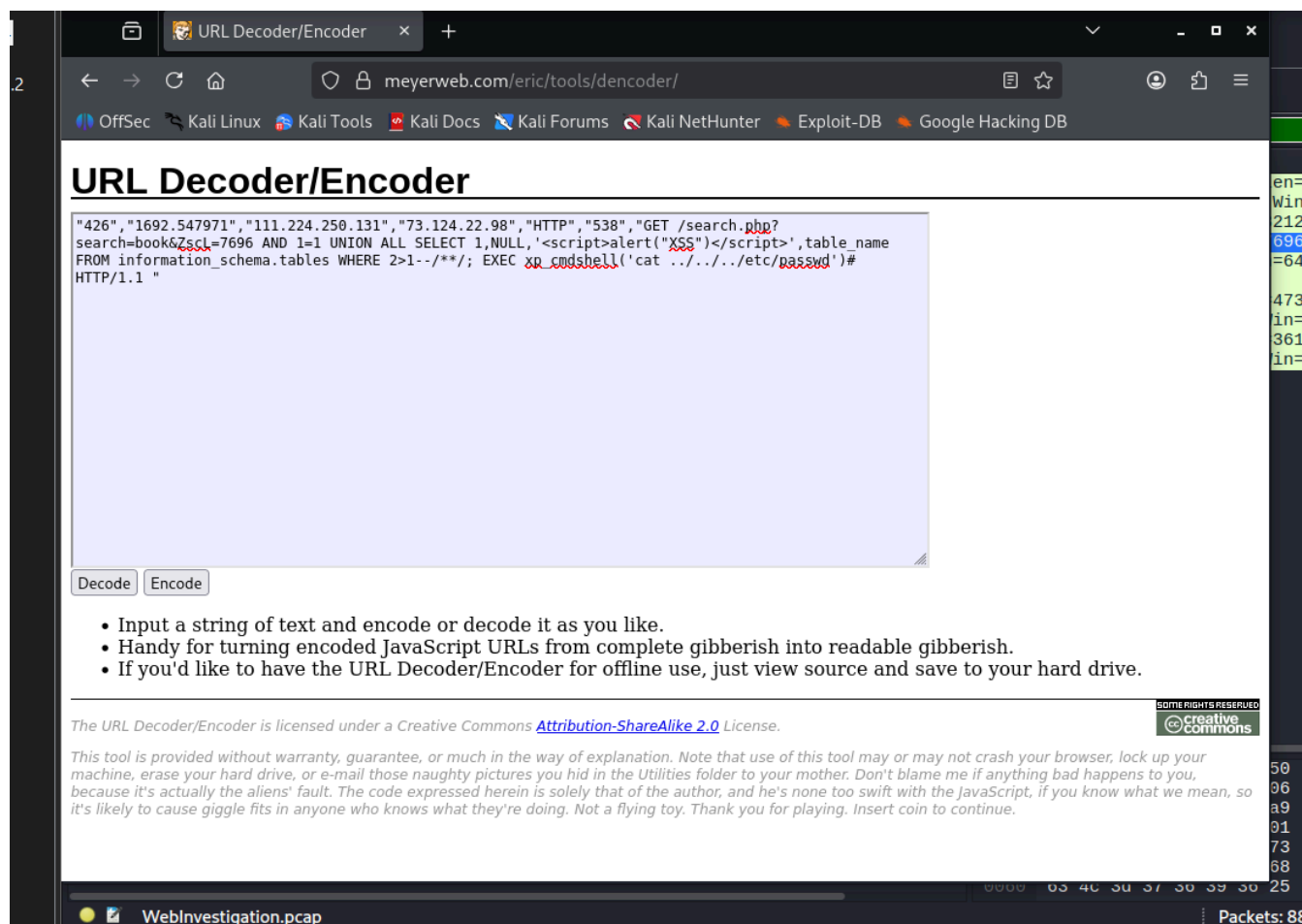
Frame 428: Packet, 425 bytes
Ethernet II, Src: VMware_6c:
Internet Protocol Version 4,
Transmission Control Protocol
Hypertext Transfer Protocol
Line-based text data: text/html

client pkt, 1 server pkt, 1 turn.

Entire conversation (864 bytes) Show as ASCII No delta times Stream 42

Find: Case sensitive Find Next

Filter Out This Stream Print Save as... Back Close Help



1. HTTP requests containing UNION ALL SELECT
2. Access to information_schema.tables
3. SQLMap User-Agent observed in traffic
4. Large HTTP data transfers between attacker and server

Conclusion

The attack was conducted through SQL injection against the BookWorld web application, leading to database enumeration and possible customer data exposure.

Exercise 8:

Submit a professional forensic investigation report.

BOOKWORLD EXECUTIVE BRIEFING

Overview

BookWorld experienced a cyberattack targeting its online book search feature. The attacker exploited a weakness in the website to gain unauthorized access to database information.

Business Impact

- Potential exposure of customer information.
- Risk of reputational damage.
- Possible violation of data protection requirements.

Key Risks

- Unauthorized access to sensitive records.
- Future attacks if the vulnerability remains unpatched.
- Loss of customer trust.

Recommended Actions

- Fix the vulnerable web application immediately.
- Conduct a full security review of customer databases.
- Implement stronger monitoring and intrusion detection.
- Perform regular security testing and patch management.

Conclusion

Immediate remediation and enhanced security controls are required to prevent future data breaches and protect customer information.

